

Secure Coding Review

CodeAlpha Cyber Security Internship - Task 3

Prepared by: **Hayden Wessels**

Executive Summary

This report reviews a basic Python login system and identifies security weaknesses that could expose user accounts to unauthorized access. The review focuses on hardcoded credentials, weak passwords, plain text password storage, missing input validation, unlimited login attempts, and poor security controls. Safer coding recommendations and an improved version of the code are included.

1. Project Objective

The objective of this task is to perform a secure coding review on a simple application, identify vulnerabilities, explain the risks, and recommend secure coding improvements.

2. Application Reviewed

The application reviewed is a simple Python login system. The original version allows users to enter a username and password, then checks those details against a small user list stored directly inside the source code.

3. Review Methodology

The review was completed using manual code inspection and secure coding best practices. The code was checked for common weaknesses such as insecure credential storage, weak authentication controls, missing validation, and unsafe handling of sensitive information.

4. Vulnerability Findings

Finding	Risk	Severity	Recommendation
Hardcoded Credentials	Username and passwords are written directly inside the source code.	High	Store credentials securely outside the code and never commit real passwords to GitHub.
Weak Passwords	Passwords such as admin123 and password123 are easy to guess.	High	Use strong passwords and enforce password complexity rules.
Plain Text Password Storage	Passwords are stored as readable text instead of secure hashes.	High	Store password hashes using bcrypt, Argon2, or PBKDF2 with salts.
No Input Validation	The program accepts any username input without checking format or length.	Medium	Validate input length, characters, and expected format.
No Account Lockout	Attackers can attempt unlimited passwords	Medium	Limit failed login attempts and add temporary lockout

	without being blocked.		controls.
Basic Error Handling	The program gives simple output and has no logging or monitoring.	Low	Use safer error messages and log suspicious authentication activity.

5. Example of Vulnerable Code

```
users = {
    "admin": "admin123",
    "hayden": "password123"
}

username = input("Username: ")
password = input("Password: ")

if username in users and users[username] == password:
    print("Login successful")
else:
    print("Invalid login details")
```

6. Secure Coding Recommendations

- Never store real usernames or passwords directly in source code.
- Use secure password hashing algorithms such as bcrypt, Argon2, or PBKDF2.
- Validate all user input before processing it.
- Limit failed login attempts to reduce brute-force attacks.
- Use two-factor authentication for sensitive systems.
- Avoid exposing sensitive information in error messages.
- Keep secrets in environment variables or a secure secrets manager.

7. Improved Security Controls Implemented

An improved version of the login system was created to demonstrate safer practices. The improved version includes password hashing, input validation, hidden password input, secure string comparison, and a maximum login attempt limit.

8. Conclusion

The secure coding review shows that even a small login system can contain serious vulnerabilities if security is not considered during development. By removing hardcoded credentials, hashing passwords, validating inputs, and limiting login attempts, the application becomes safer and more resistant to common attacks.

9. References

1. OWASP Foundation. (2021). OWASP Top 10 Web Application Security Risks. Available at: <https://owasp.org/www-project-top-ten/>
2. OWASP Foundation. (n.d.). Authentication Cheat Sheet. Available at: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
3. Python Software Foundation. (n.d.). hashlib - Secure hashes and message digests. Available at: <https://docs.python.org/3/library/hashlib.html>